

Active Directory Risk Assessment Lab

Maple Equity Lending (MEL)

Scenario

Maple Equity Lending is a Canadian private mortgage lender serving homeowners with strong equity who may not qualify through traditional banks. The company stores sensitive customer information, making Active Directory (AD) a critical system. I was asked to assess the security risks within the AD environment and recommend improvements.

Objectives

Evaluate Active Directory security, identify risks, review existing controls, and recommend practical improvements.

Key Findings and Recommendations

Shared Domain Admin Account

Risk: Everyone in IT uses the same administrator account.

Recommendation: Create named administrator accounts and implement Privileged Access Management (PAM).

Weak Password Policy

Risk: Passwords require only eight characters and administrators do not use MFA.

Recommendation: Require 14+ character passwords, enable Multi-Factor Authentication (MFA), and configure account lockout policies.

Old Employee Accounts

Risk: Former employee accounts remain active.

Recommendation: Automate account deprovisioning during HR offboarding.

Excessive Access

Risk: Loan Officers can access HR folders.

Recommendation: Review NTFS permissions and implement Role-Based Access Control (RBAC).

Too Many Domain Admins

Risk: More users have administrative rights than necessary.

Recommendation: Apply the principle of least privilege and review privileged access quarterly.

Service Accounts

Risk: Service account passwords never expire.

Recommendation: Use Group Managed Service Accounts (gMSAs).

Limited Monitoring

Risk: Privileged changes are not monitored.

Recommendation: Enable Advanced Audit Policy and send logs to a Security Information and Event Management (SIEM) platform.

Abbreviations

Abbreviation	Meaning
AD	Active Directory
HR	Human Resources
IT	Information Technology
MFA	Multi-Factor Authentication
PAM	Privileged Access Management
RBAC	Role-Based Access Control
NTFS	New Technology File System (Windows file permission system)
GPO	Group Policy Object
gMSA	Group Managed Service Account
SIEM	Security Information and Event Management
PII	Personally Identifiable Information
NIST	National Institute of Standards and Technology
CSF	Cybersecurity Framework
COBIT	Control Objectives for Information and Related Technology
ISO	International Organization for Standardization

Conclusion

The assessment identified several identity and access management weaknesses that increase the risk of unauthorized access and data exposure. Addressing these recommendations would significantly improve the organization's security posture.